

synth-attest: An Open, Vendor-Neutral Verifiable-Identity and Tamper-Evident Audit Layer for DNA-Synthesis Order Compliance

Pavan Kumar Dubasi
Independent
pavankumar.dubasi2019@gmail.com

Abstract—DNA-synthesis screening answers whether a sequence is dangerous, but not who ordered it, whether they are a verified researcher, or whether a trustworthy record of the decision exists. As regulation (the proposed US Biosecurity Modernization and Innovation Act, the US OSTP framework, UK DSIT guidance, and the proposed EU Biotech Act) converges on mandating customer identity verification and recordkeeping, no shared, vendor-neutral tooling exists; commercial entrants use centralized, per-provider Know-Your-Customer (KYC) workflows. We present **synth-attest**, an open-source layer that sits on top of (and never replaces) sequence screening, adding three capabilities built on W3C standards: a portable researcher-identity credential, a provider-issued revocable exemption credential, and a privacy-preserving, tamper-evident order-audit record. The design is vendor-neutral by construction: the core has zero proprietary dependencies and runs on a dependency-free reference engine, with any W3C Verifiable Credential backend pluggable behind a stable interface. We report a working prototype (592 lines of core Python, 33 tests) validated in continuous integration on Python 3.11 and 3.12 in two configurations: a no-proprietary-dependency core (23 passed, 10 backend tests skipped) and an optional backend validated source-blind against its published package (33 passed). We state the threat model honestly, scoping the contribution to fraud, attribution, and deterrence at the acquisition node.

Index Terms—biosecurity, DNA synthesis, verifiable credentials, decentralized identifiers, audit trails, know-your-customer, compliance

I. INTRODUCTION

Advances in machine learning lower the barrier to designing biological sequences of concern, making the nucleic-acid synthesis-order step one of the few remaining physical chokepoints for governance. Sequence-screening systems such as SecureDNA [1] and the IBBIS Common Mechanism [2] assess whether an ordered sequence matches a hazard, but they do not establish *who* is ordering, whether that customer is a verified and legitimate researcher, or whether the order decision leaves a tamper-evident, independently verifiable record. Recent and proposed regulation, including the US Biosecurity Modernization and Innovation Act of 2026 [3], the US OSTP nucleic-acid-synthesis framework, UK DSIT screening guidance [4], and the proposed EU Biotech Act, pushes providers toward customer identity verification and

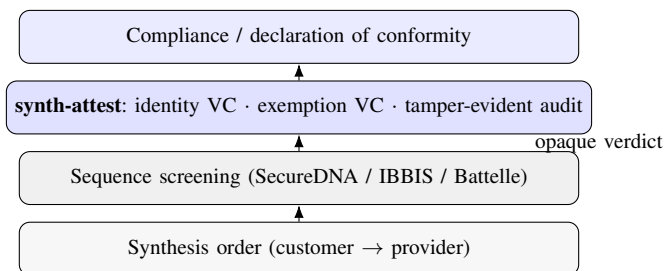


Fig. 1. Layered architecture. **synth-attest** adds an identity and audit layer above sequence screening, which it never replaces. Only an opaque verdict (cleared / flagged / tier-review) crosses the boundary; no sequence data enters the layer.

recordkeeping. No shared, portable tooling exists to meet these obligations; commercial entrants address them with closed, per-provider KYC workflows.

We present **synth-attest**, an open, vendor-neutral layer that adds the missing identity and audit capabilities on top of existing screening. It is deliberately scoped: it does not screen sequences and never handles sequence data.

II. THREAT MODEL AND HONEST SCOPE

We map the engineered-pandemic kill chain as: capability uplift, acquire materials, synthesize, weaponize, release. **synth-attest** intervenes at a single node, *acquire materials*, and only for actors routing through compliant providers. It addresses three failure modes there: identity fraud (spoofed or unverified customers), weak attribution (no portable record of who ordered what), and low deterrence. It explicitly does *not* address capability uplift, benchtop or non-compliant synthesis, weaponization, or a genuinely credentialed malicious insider; identity proves identity, not intent. Any claim that the layer “prevents engineered pandemics” is unsupported and avoided.

III. DESIGN

synth-attest provides three artifacts and one privacy property (Fig. 1).

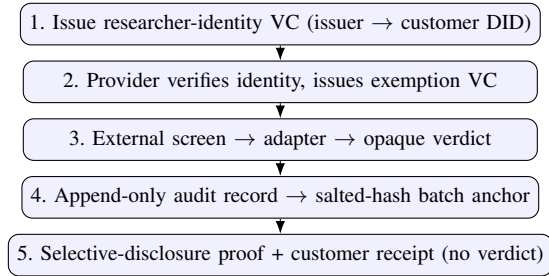


Fig. 2. End-to-end order flow, implemented as the project demo and runnable on both engines.

A. Portable researcher-identity credential

A W3C Verifiable Credential [5] bound to a Decentralized Identifier [6] asserts a verified researcher and institutional affiliation only. It is explicitly not a clearance, and carries no risk-tiering field. Portability lets a researcher avoid re-onboarding at every provider, addressing the documented gap that customer screening is currently re-performed per provider and rarely shared.

B. Provider-issued exemption credential

Following existing exemption-certification practice, an exemption credential is issued by the provider (which retains regulatory liability) to authorize a sequence *class*, never a sequence. It is time-bound and revocable. This separates the portable identity (about the person) from the order-specific authorization (the provider’s local decision), correcting a common conflation between credentialing a person and clearing an order.

C. Privacy-preserving tamper-evident audit

Each order decision produces an append-only, signed record held by the provider. Only a salted SHA-256 commitment over (salt, order id, verdict, customer DID) is anchored, and commitments are anchored in fixed-size batches of $B = 16$, padded with indistinguishable random fillers and sorted, so that order volume, timing, and the screening verdict are not recoverable from what is anchored. A customer-facing receipt never contains the verdict, preventing the audit channel from becoming a screening-evasion oracle.

D. Infohazard guard

No sequence-like data may enter the layer. A guard rejects any payload containing a nucleotide-alphabet ($[ACGTU]$) run of length ≥ 20 , erring toward false positives, the safe direction for an infohazard boundary.

IV. VENDOR NEUTRALITY

The core has zero proprietary dependencies. A dependency-free reference engine (*StubEngine*) implements the full contract (issue, verify, detect tampering, revoke, selectively disclose), so the entire flow runs with only the Python standard library. A swappable *CredentialEngine* interface allows any conformant W3C VC/DID backend; an optional adapter

TABLE I
ARTIFACTS AND THEIR KEY PROPERTIES

Artifact	Issuer	Key property
Researcher identity VC	registry	portable; identity only, no tier
Exemption VC	provider	sequence- <i>class</i> , time-bound, revocable
Order audit record	provider	salted SHA-256, batch $B=16$ anchor
Disclosure proof	holder	selective; reveals chosen fields only

TABLE II
VALIDATION RESULTS (CONTINUOUS INTEGRATION)

Configuration	Passed	Skipped
Core only (no proprietary dependency)	23	10
Optional backend (source-blind, published)	33	0
Python 3.11 and 3.12; 33 tests collected; 592 LOC core.		

(*AttestixEngine*) is provided but not required, and auto-detects the backend’s service or functional surface. Continuous integration enforces independence: one job installs the core, *asserts the optional backend is absent*, and runs the suite; a second installs the optional backend and validates it source-blind against the published package.

V. IMPLEMENTATION AND VALIDATION

The prototype is 592 lines of core Python across five modules (engine, schemas, audit, adapters, custody), plus reference adapters that map SecureDNA-shaped and IBBIS-Common-Mechanism-shaped screening results to the three opaque verdicts, and a custodial registry so researchers need not operate a key wallet (a provider or neutral registry custodies the credential, keyed by a salted hash of an identifier). Every credential and audit field is traced to a named regulatory obligation, each marked verified or unverified, and a test fails if any schema field lacks a mapping row. Table I summarizes the artifacts; Table II reports validation. The suite is 33 tests; in the no-proprietary-dependency configuration 23 pass and the 10 backend-specific tests skip, and with the optional backend active (validated source-blind against the published package) all 33 pass. Both configurations are green in CI on Python 3.11 and 3.12.

Three properties are demonstrated by dedicated tests rather than asserted: (i) tampering with any credential field causes verification to fail; (ii) a revoked credential fails verification and cannot be presented; and (iii) the anchored batch root has fixed width and does not reveal the number of real orders in the batch, so order volume is not recoverable from what is anchored.

VI. RELATED WORK AND POSITIONING

Sequence-screening systems [1], [2] are complementary, not competing; synth-attest consumes their verdicts as opaque tokens. Commercial KYC entrants for synthesis providers use centralized identity verification and per-provider recordkeeping. The distinguishing properties of synth-attest are portable

W3C credentials, cross-provider tamper-evident audit, and an open, vendor-neutral implementation, none of which the centralized approaches provide.

VII. LIMITATIONS AND FUTURE WORK

The reported results are functional and integration tests of a prototype, not an empirical study of deployed effectiveness. The exemption and audit models are validated against published descriptions of real screening practice but not yet against a live provider integration. A credential-tiering field is deliberately omitted pending confirmation that any real framework tiers researcher clearance rather than data sensitivity. An issuer trust-root design (accrediting identity issuers without recreating a centralized authority) is the principal open architectural question. Throughput and anchor-cost at realistic order volumes, and a live screening integration, are the next validation steps.

VIII. CONCLUSION

synth-attest supplies the identity and audit layer that sequence screening leaves open, as an honest, narrowly scoped, and vendor-neutral open-source contribution to nucleic-acid synthesis governance.

APPENDIX A

REPRODUCIBILITY OF REPORTED FIGURES

All numeric claims are mechanically checkable from the public repository at the cited commit: 592 LOC (`wc -l src/synth_attest/*.py`); 33 tests collected (`pytest --co`); 23 passed / 10 skipped core and 33 passed with the optional backend (`pytest`); batch size $B=16$ and the SHA-256 commitment (`src/synth_attest/audit.py`); the length-20 [ACGTU] guard (`src/synth_attest/schemas.py`); optional backend version pinned in `pyproject.toml`. The two CI configurations are defined in `.github/workflows/ci.yml`.

REFERENCES

- [1] SecureDNA Foundation, “Verifiably and privately screening global DNA synthesis,” 2024. <https://securedna.org/>
- [2] International Biosecurity and Biosafety Initiative for Science, “The Common Mechanism for DNA Synthesis Screening.” <https://ibbis.bio/common-mechanism/>
- [3] US Senate, “Biosecurity Modernization and Innovation Act,” S.3741, 119th Congress, 2026.
- [4] UK Department for Science, Innovation and Technology, “Screening guidance on synthetic nucleic acids for users and providers,” 2024.
- [5] W3C, “Verifiable Credentials Data Model,” W3C Recommendation.
- [6] W3C, “Decentralized Identifiers (DIDs) v1.0,” W3C Recommendation, 2022.